BRIEFING TÉCNICO

Sistema de gestão Forró do Rei

Arquitetura, módulos, regras de negócio, segurança e operação

Documento gerado em 05/11/2026 a partir do código-fonte (pacote de atualização) e de capturas de tela do sistema em
Versão do banco (schema.version): 26 · Stack: PHP 8.1+ e MySQL/MariaDB, sem frameworks externos.

1. Visão geral

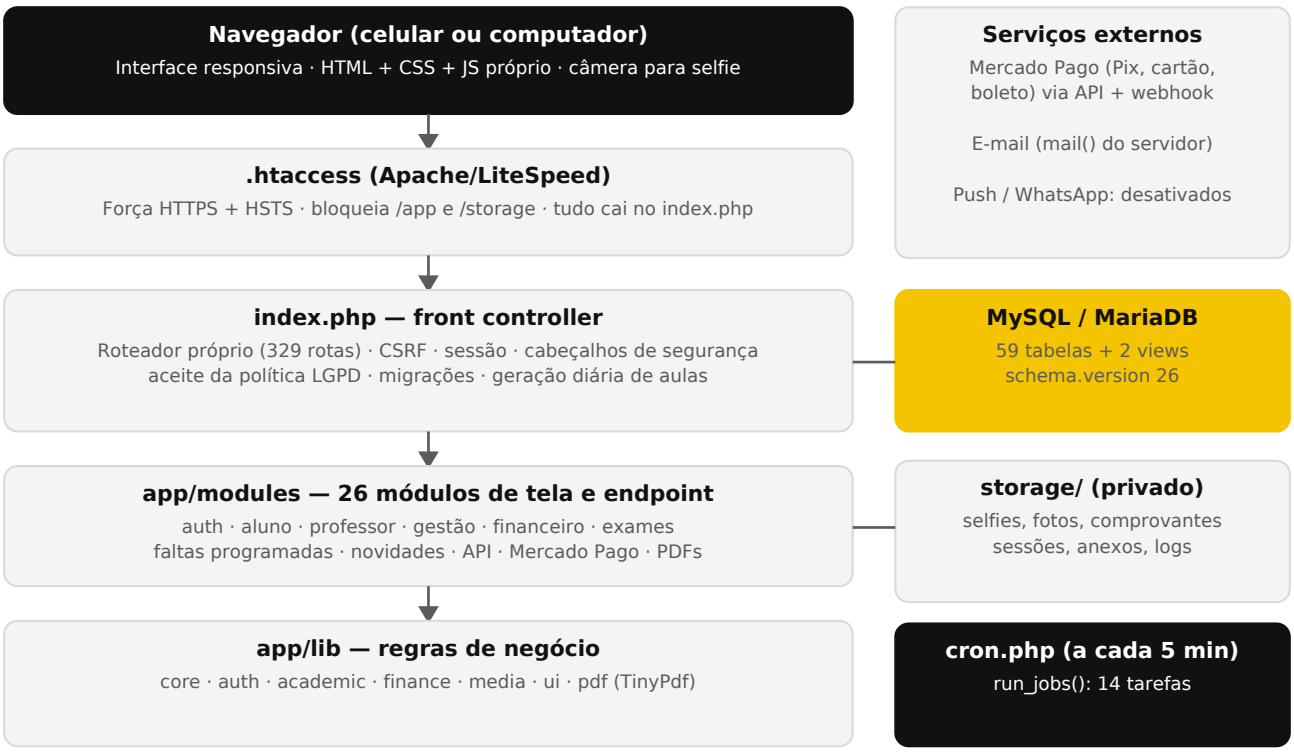
O sistema do **Forró do Rei** é uma aplicação web responsiva (celular e computador) que concentra a operação de uma escola de forró com **cinco unidades** (Centro, São Mateus, Benfica, Quintas e Fábrica): cadastro de pessoas, turmas e grade de aulas, matrículas e planos, presença por selfie, reposições, bolsistas, exames de troca de colar com certificado, financeiro completo (cobranças, recebimentos, despesas, caixa), remuneração de professores por hora-aula, galeria de fotos, comunicados e conformidade com a LGPD.

Hoje ele é usado pela própria escola, com perfis separados para **direção, alunos, professores, bolsistas e desenvolvedor**. Roda em hospedagem compartilhada da Hostinger, sem dependências externas de código (nenhum framework, Composer ou npm).

Indicador	Valor	Observação
Código PHP	≈ 13,8 mil linhas	26 módulos (telas + endpoints) e 7 bibliotecas em app/lib
Front-end	≈ 640 linhas	assets/app.js e assets/app.css, sem framework
Rotas HTTP	329	Roteador próprio no index.php; CSRF automático em escrita
Banco de dados	59 tabelas + 2 views	Schema de 1.128 linhas; migrações versionadas (versão 26)
Perfis de acesso	7	Administrador (Direção geral), Aluno, Professor, Bolsista, Recepção, Coordenação e Desenvolvedor
Permissões	28 + 3 novas	Base do schema + exams.cancel, units.dashboard e org.manage
Tarefas agendadas	14	Executadas pelo cron.php a cada 5 minutos
API documentada	OpenAPI 3.0.3	app/openapi.yaml (13 operações principais)

2. Arquitetura

A aplicação é um **monólito PHP** com *front controller*. Toda requisição que não é um arquivo estático passa pelo `index.php`, que carrega as bibliotecas, registra as rotas de cada módulo em `app/modules/*.php`, valida sessão e CSRF, e despacha para o handler.



Fluxo geral: navegador → .htaccess → index.php → módulo → biblioteca → banco/storage. O cron e o webhook do Mercado Pago entram por caminhos próprios.

Estrutura de pastas

```
index.php       front controller (rotas, cabeçalhos, sessão)
cron.php        tarefas agendadas (somente linha de comando)
assets/         CSS, JS, logo, favicon e imagens dos 7 colares
app/config.php  credenciais e chaves (bloqueado pela web)
app/lib/        core · auth · academic · finance · media · ui · pdf
app/modules/    26 módulos: 01_auth … 26_mercadopago
app/sql/        schema.sql e tabela_valores.sql
app/views/      layout e página de erro
storage/        mídia privada, sessões, anexos e logs (bloqueado pela web)
```

Decisões técnicas relevantes

- **Sem dependências:** o gerador de PDF (`TinyPdf`) é próprio, escrito em PHP, com Helvetica e imagens JPEG. Isso simplifica a hospedagem compartilhada, mas limita recursos de layout.
- **Datas em UTC:** o banco guarda tudo em UTC e a interface converte para America/Sao_Paulo (constante LOCAL_TZ). Valores financeiros são guardados em **centavos**.
- **Auto-instalação e migrações:** a cada requisição o sistema confere a versão do schema e aplica migrações pendentes (`run_migrations`, hoje na versão 26).
- **Jobs “leves” também rodam durante o uso** (geração diária de aulas, fechamento de aulas e faltas). O sistema continua coerente mesmo se o cron falhar, mas as demais tarefas dependem dele.
- **Detecção do caminho de instalação:** o app funciona na raiz do domínio ou em subpasta (hoje em /forrodorei).

3. Perfis, permissões e organização

O acesso é controlado por **perfis** (papéis) com **permissões** granulares, concedidos de forma **global** ou **por unidade** (tabelas `user_global_roles` e `user_unit_roles`). Quem tem mais de um perfil escolhe como quer atuar no seletor “Você está como”, no topo do menu lateral.

Perfil	O que faz no sistema
Direção geral (admin)	Acesso total: pessoas, planos, turmas, matrículas, financeiro, exames, configurações, auditoria, exclusões, abono de falta.
Aluno	Início, aulas e reservas, mensalidades e pagamento online, fotos, frequência, reposições, diário de aulas, exames de colar e certificados, eventos.
Professor	Aulas de hoje com Iniciar/Finalizar (hora-aula pelo tempo efetivo), chamada, programar falta, substituições, aulas ministradas, financeiro próprio, equipe do dia.
Bolsista	Faz aula do colar e cumpre contrapartida de apoio (1 dia de aula + 1 dia de apoio); check-in de apoio, aviso de falta no apoio e reposição de apoio.
Recepção / Coordenação	Perfis de apoio: cadastro, matrículas, reservas, interessados e validação de presença (recepção); acompanhamento acadêmico (coordenação).
Desenvolvedor	Acesso a tudo e exclusivo em “Gerenciar novidades” (publica o que mudou no sistema, com anexos e botão □). Concedido uma vez pela direção; depois só outro Desenvolvedor concede ou revoga.



Figura 1 — Seletor "Você está como" no menu lateral: Direção geral, Aluno, Professor, Bolsista e Desenvolvedor.

Permissões base (28)

users.manage · roles.manage · units.manage · catalog.manage · classes.manage · schedule.manage · sessions.manage · plans.manage · enrollments.manage · scholarships.manage · attendance.validate · attendance.correct · bookings.manage · leads.manage · events.manage · announcements.manage · albums.publish · albums.moderate · progress.write · finance.view · finance.invoices · finance.payments · finance.refunds · finance.expenses · payroll.manage · reports.view · settings.manage · audit.view. Acrescidas por atualizações: **exams.cancel**, **units.dashboard** e **org.manage**.

Organograma

Em Gestão → Organograma ficam direção geral, direção financeira, equipe administrativa, diretor de unidade (opcional), professores, monitores e bolsistas. Ao atribuir uma pessoa a um cargo, ela recebe automaticamente o perfil ligado a ele, na unidade do cargo ou em todas.

4. Telas do sistema (produção)

Capturas feitas em 05/11/2026 no ambiente de produção (aqua-yak-316559.hostingersite.com). A interface usa menu lateral escuro com destaque amarelo e vira barra inferior no celular.

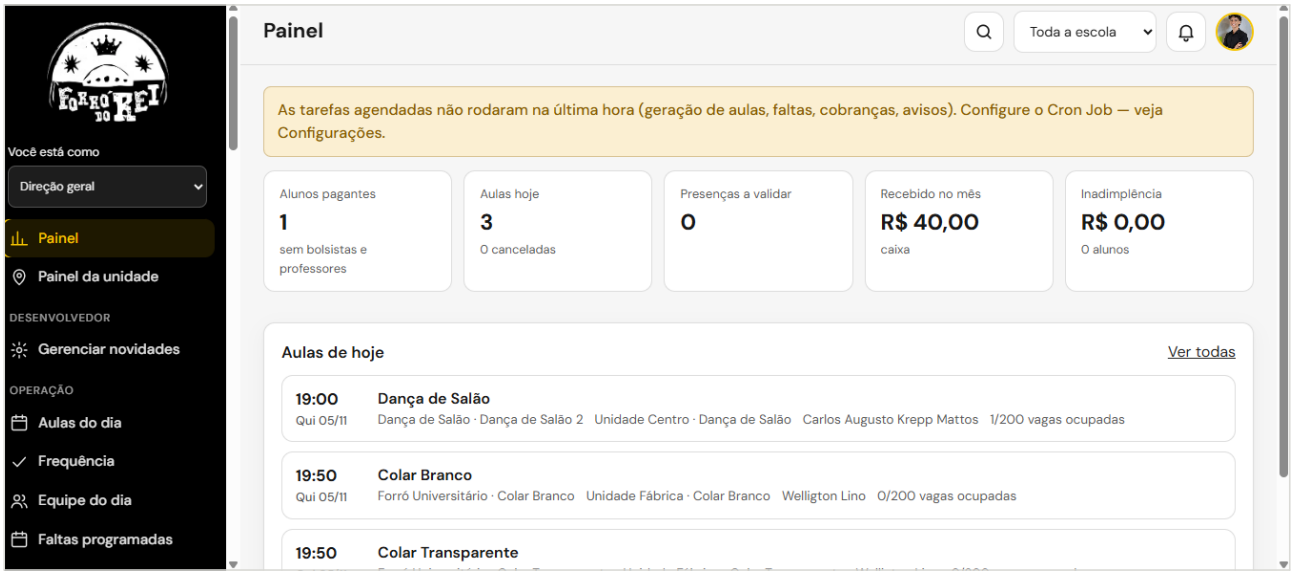


Figura 2 — Perfil Direção geral: Painel com alunos pagantes, aulas de hoje, presenças a validar, recebido no mês e inadimplência. O aviso amarelo no topo indica que as tarefas agendadas não rodaram na última hora (ver seção 10).

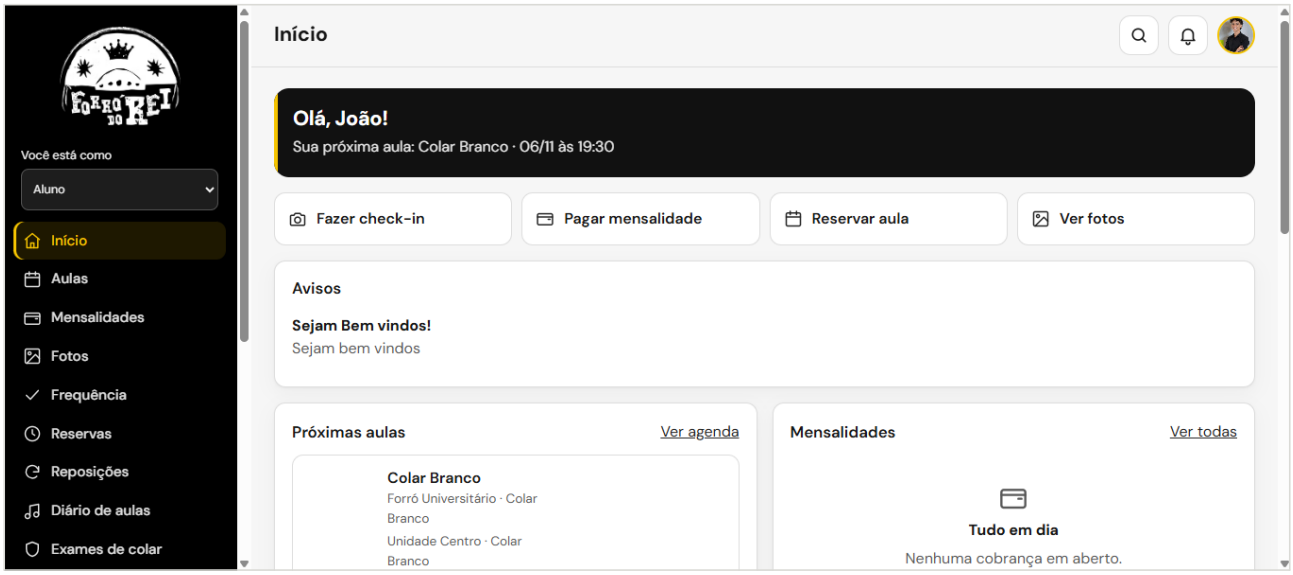


Figura 3 — Perfil Aluno: Início com próxima aula, atalhos (check-in, pagar mensalidade, reservar aula, fotos), avisos, próximas aulas e mensalidades.

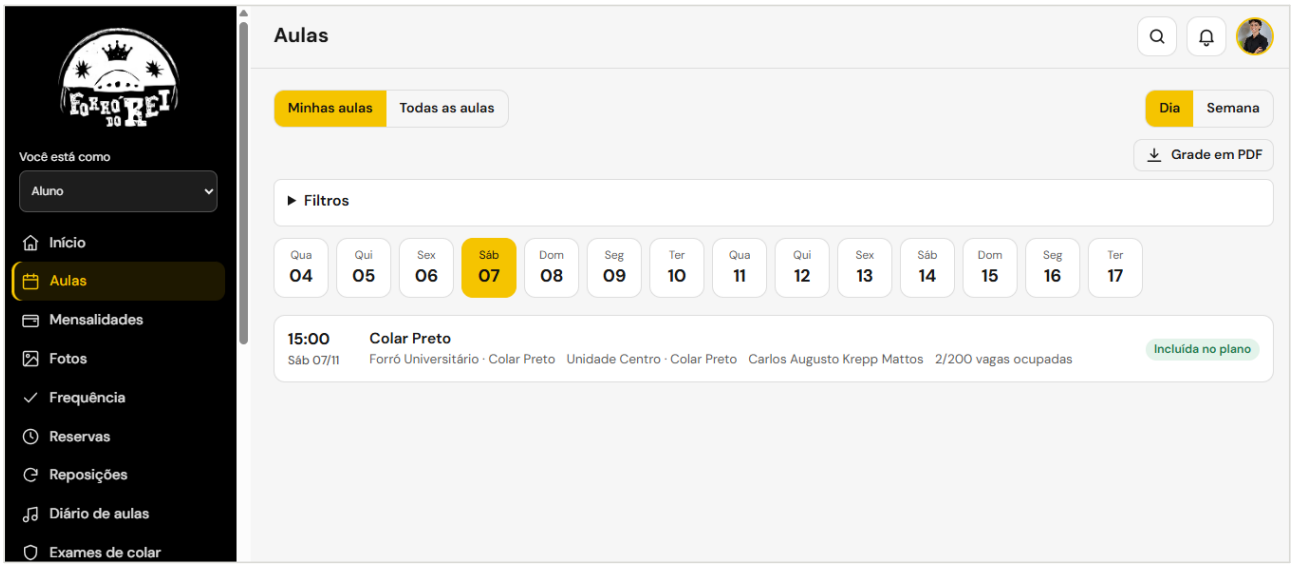


Figura 4 — Perfil Aluno: agenda de aulas com seletor de dias, filtros, alternância Minhas aulas / Todas as aulas e exportação da Grade em PDF.

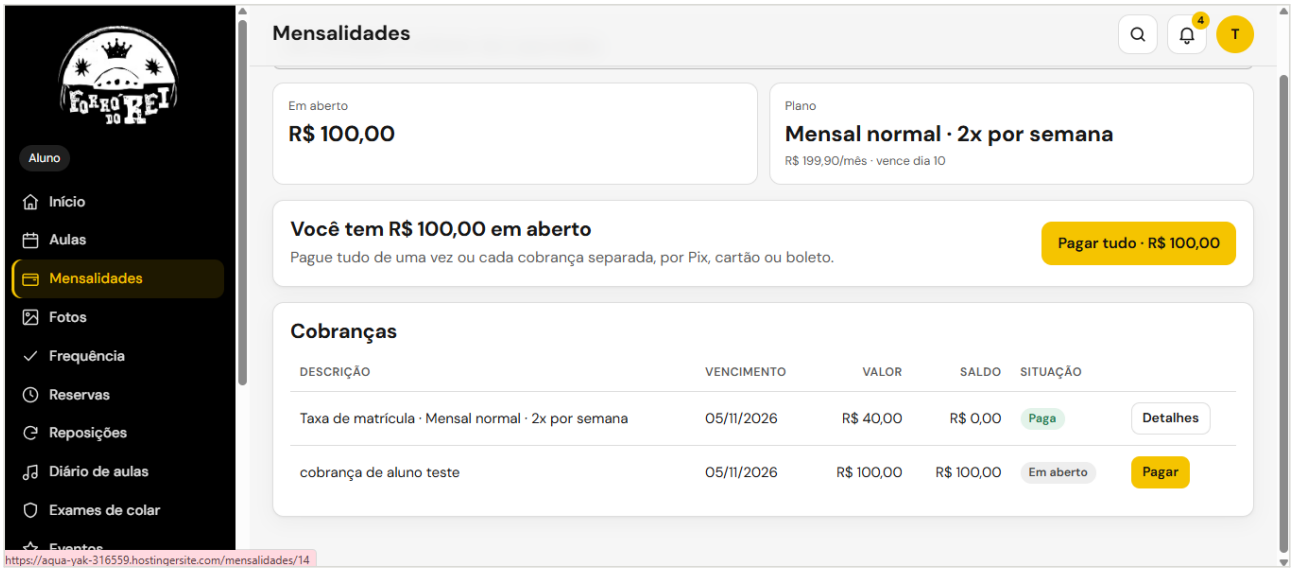


Figura 5 — Perfil Aluno: Mensalidades, com plano contratado, saldo em aberto, "Pagar tudo" e lista de cobranças com Detalhes ou Pagar por linha.

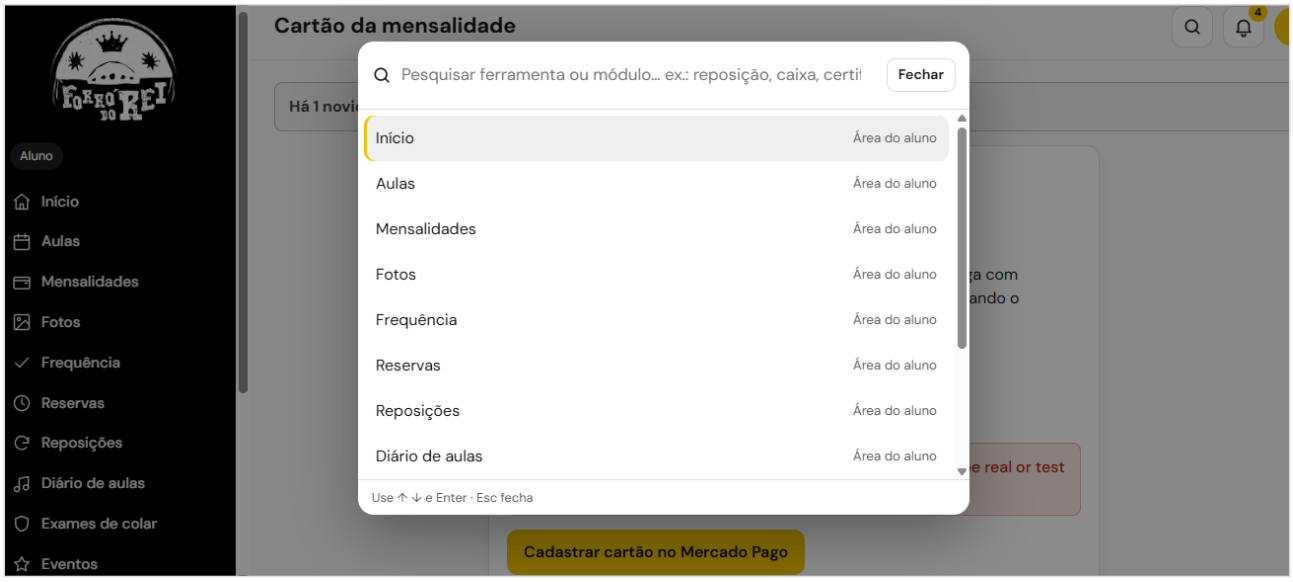


Figura 6 — Busca global de ferramentas (lupa no topo; atalho "/" ou Ctrl+K). Mostra somente módulos aos quais a pessoa tem acesso.



Figura 7 — Versão celular (iPhone SE, 375 px): Aulas do dia da gestão, com filtros de dia, unidade e professor e navegação inferior fixa.

5. Módulos funcionais

Área	Principais funções	Módulos
Acesso	Login com limite de tentativas, convite por e-mail, recuperação de senha, 2º fator (TOTP) obrigatório ao administrador, aceite LGPD e tutorial de boas-vindas.	01, 24
Aluno	Início, aulas, reservas e fila de espera, check-in com selfie, frequência, reposições, diário de aulas, fotos, eventos, mensalidades, perfil e foto.	02, 11
Professor	Aulas de hoje (Iniciar/Finalizar), chamada, aulas ministradas, programar falta, substituições, equipe do dia, financeiro e pagamentos recebidos.	04, 18, 25

Área	Principais funções	Módulos
Gestão acadêmica	Pessoas, unidades, modalidades e níveis (colares), turmas, horários semanais, grade (geração de 4 semanas), matrículas por dia fixo, bolsas, feriados.	05, 06, 19
Operação	Aulas do dia, frequência (CSV), faltas programadas e cronograma dos professores, reposições automáticas (aluno e apoio de bolsista), interessados e aulas experimentais.	06, 08, 25
Financeiro	Planos e pacotes, cobranças e ajustes, recebimentos com rateio, estornos, despesas e rateio entre unidades, livro-caixa, comparativo de unidades, fechamento de professores.	07, 12, 19
Exames de colar	Exames, inscrição como condutor/conduzido, ficha de avaliação configurável, resultado final, certificado PDF com código verificável, cancelamento com restauração de colar.	10, 22, 23
Comunicação	Comunicados, notificações internas, e-mails em fila, galeria de fotos com retenção e pedidos de retirada, novidades do sistema.	08, 21
Relatórios e PDFs	Grade semanal, PDF de planos personalizado, lista de aprovados, listas e totais (PDF e Excel), demonstrativo do professor, certificados.	14–17
Governança	Auditoria de ações sensíveis, exclusões controladas, privacidade (LGPD), pesquisa global, organograma e permissões.	13, 20, 23, 24

6. Modelo de dados

59 tabelas e 2 views (`v_invoice_balances` e `v_teacher_earnings_approved`), em MySQL 8 / MariaDB 10.11. O saldo de cada cobrança é **derivado** por view a partir de cobranças, ajustes e alocações de pagamento, e não gravado.

Domínio	Tabelas principais
Identidade e acesso	users, roles, permissions, role_permissions, user_global_roles, user_unit_roles, auth_tokens, login_attempts, student_profiles, teacher_profiles
Estrutura acadêmica	units, disciplines, levels, classes, class_schedules, schedule_teachers, class_sessions, session_teachers, session_roster
Matrícula e planos	plans, plan_units, plan_classes, enrollments, enrollment_history, enrollment_classes
Presença e reservas	attendance, bookings, makeup_requests, media_objects, trial_bookings, learning_progress
Bolsas	scholarships, scholar_activities, scholar_activity_attendance
Financeiro	invoices, invoice_adjustments, payments, payment_allocations, refunds, payment_webhooks, expenses, expense_categories, expense_payments
Professores (pagamento)	teacher_rates, payroll_periods, teacher_earnings, teacher_payouts
Eventos e comunicação	events, event_registrations, announcements, notifications, notification_preferences, albums, album_photos, image_preferences, photo_removal_requests, leads
Configuração e auditoria	school_settings (parâmetros em JSON), audit_logs

Tabelas de exames, faltas programadas, organograma, novidades, certificados e feriados foram criadas pelas migrações posteriores (versões 2 a 26) e não constam na lista acima do schema inicial.

7. Regras de negócio principais

Tema	Como funciona
Presença	Cada pessoa registra só a própria presença. Aluno e bolsista com selfie; professor com selfie ou botão “Registrar minha presença”. Aula terminada sem registro vira falta automaticamente. A equipe pode dispensar, justificar ou invalidar check-in suspeito; só o administrador “dá presença” (abono) com justificativa auditada.
Reposição	Toda falta gera reposição automática: qualquer dia e unidade, aula do mesmo colar, com vaga, em até 15 dias úteis (feriados não contam; parâmetro makeup.business_days). Para bolsistas existe a reposição de apoio, também em 15 dias úteis.
Matrícula por dia fixo	Marca-se turma + dia da semana. O plano limita os dias (1x = 1 dia; 2x = 2 dias). Aulas opcionais não geram falta. Professor e bolsista têm matrícula de aluno sem taxa e fora do total de pagantes.
Planos e pacotes	Plano com valor da parcela, pacote em meses (Ouro = 8, Prata = 4, mensal sem fidelidade), taxa de matrícula (R$ 35,00 na tabela padrão) e aulas por semana. Tabela de 6 planos cadastrável com um clique.
Cobrança	Mensalidades geradas pelo cron no início do mês; lembrete 3 dias antes e aviso no dia seguinte ao vencimento. Baixa por Pix manual, presencial ou Mercado Pago. Baixa automática da cobrança mais antiga para a mais nova.
Hora-aula do professor	Pagamento = (minutos aprovados ÷ 60) × valor da hora, pelo tempo efetivo entre Iniciar e Finalizar aula. Atraso desconta; tempo extra só com aprovação. Fechamento do mês gera despesa por unidade e demonstrativo em PDF.
Faltas programadas	Professor programa faltas futuras (até 120 dias) e a direção aprova ou recusa. O substituto assume a aula e recebe pelas horas. Sem substituto, o professor não conta falta nem recebe.
Bolsas	1 dia de aula do colar + 1 dia de apoio. Falta sem check-in no apoio é registrada sozinha; alerta à direção se a frequência ficar abaixo do mínimo configurado.
Exames de colar	Sete colares (Transparente, Branco, Azul, Roxo, Preto, Prata, Dourado). Resultado: Aprovado, Não aprovado ou Para pensar, com mais de um examinador. Ao liberar, o colar da função (condutor ou conduzido) é atualizado e o certificado PDF é gerado.

8. Pagamentos e integrações

Dois modos de operação, controlados por configuração:

- **Padrão (sem provedor):** o aluno vê a chave Pix, o pagamento fica “pendente” e a equipe confirma em Recebimentos, inclusive baixa presencial com rateio entre cobranças.
- **Mercado Pago (opcional):** checkout com Pix, cartão e boleto, pagamento de todas as cobranças de uma vez e confirmação por **webhook** que só vale após consultar a API do provedor. O Access Token e a assinatura secreta ficam **criptografados no banco (AES-256-GCM)**. Dados de cartão nunca passam pelo sistema. Eventos repetidos são ignorados e falhas são reprocessadas pelo cron (até 6 tentativas).
- **E-mail:** fila de notificações enviada pelo cron via mail() do servidor, remetente nao-responda@ do domínio. **Push e WhatsApp** estão previstos, porém desativados.

API REST (OpenAPI)

Endpoint	Função
GET /api/me	Sessão atual, papéis e papel ativo
GET /api/sessions	Grade de aulas (filtros por data, unidade, nível, professor; máx. 62 dias)
POST /api/sessions/{id}/bookings · DELETE /api/bookings/{id}	Reservar (ou entrar na fila) e cancelar reserva, promovendo a fila

Endpoint	Função
POST /api/sessions/{id}/check-ins	Check-in com selfie, idempotente (Idempotency-Key)
PATCH /api/attendance/{id}/validation	Validar ou recusar check-in
GET /api/me/invoices · POST /api/invoices/{id}/checkout	Cobranças com saldo e início de pagamento
POST /api/webhooks/payments	Webhook (mercadopago ou genérico com HMAC-SHA256)
POST /api/albums/{id}/photos · POST /api/scholar-activities/{id}/check-ins	Fotos de álbum e check-in de apoio de bolsista

Autenticação por cookie de sessão (fdr_sess) e cabeçalho X-CSRF-Token em escritas. Erros no formato {"error": {"status", "message"}}.

9. Tarefas agendadas (cron)

O `cron.php` só roda por linha de comando e deve ser agendado **a cada 5 minutos** no hPanel. Há trava de execução (cron.lock) para evitar sobreposição. Cada tarefa roda isolada: se uma falhar, as demais continuam e o erro vai para o log.

Tarefa	O que faz
gerar_ocorrencias	Gera as aulas das próximas 4 semanas a partir dos horários semanais
encerrar_aulas_e_faltas	Fecha aulas terminadas e converte pendências em falta
promover_fila	Promove lista de espera e expira reservas de aulas que já começaram
expirar_inscricoes_eventos	Libera vagas de eventos com reserva vencida
expirar_reposicoes	Expira reposições fora do prazo e sincroniza créditos
gerar_mensalidades	Emite as mensalidades do mês (uma vez por mês)
lembretes_cobranca	Avisos de vencimento próximo e de cobrança vencida
lembrete_experimental	Lembra a aula experimental 24 h antes
reprocessar_webhooks · conciliar_pendentes_mp	Reprocessa webhooks com falha e concilia pagamentos pendentes no Mercado Pago
alertas_bolsa · faltas_contrapartida	Alerta de frequência mínima e falta automática no apoio do bolsista
enviar_notificacoes	Entrega a fila de e-mails e notificações
remover_midia_vencida	Apaga selfies e fotos vencidas (retenção) e limpa tentativas de login e tokens antigos

Comando de agendamento (Hostinger)

```
*/5 * * * *  /usr/bin/php /home/<usuario>/domains/<dominio>/public_html/forrodorei/cron.php
```

10. Segurança e privacidade

Controle	Implementação
Senhas	password_hash (PASSWORD_DEFAULT) com rehash automático; nunca em texto puro.
Login	Bloqueio após 5 falhas por e-mail ou 20 por IP em 15 minutos; suspender ou trocar senha encerra as sessões (session_version).
2º fator	TOTP (Google Authenticator) obrigatório ao administrador no primeiro acesso.
Sessão	Cookie fdr_sess HttpOnly, SameSite=Lax, Secure em HTTPS, modo estrito; sessões em storage/sessions (validade de 8 h).
CSRF	Verificação automática em todo POST, PUT, PATCH e DELETE (exceto webhooks e cron).
Cabeçalhos	HSTS, X-Content-Type-Options, X-Frame-Options, Referrer-Policy e Permissions-Policy (câmera só do próprio site).
Arquivos privados	app/ e storage/ bloqueados por .htaccess; mídia só por links assinados que expiram em 15 minutos.
Auditoria	audit_logs registra autor, antes/depois e unidade em presença, financeiro, acessos, configurações, exclusões e exportações.
LGPD	Política e termos em /privacidade, aceite obrigatório com data, hora, IP e navegador, reaceite por versão, retenção configurável de selfies e fotos, exclusão com anonimização.
Segredos	Token do Mercado Pago criptografado no banco; demais segredos em app/config.php (fora do alcance da web).

11. Operação e implantação

Item	Situação
Hospedagem	Hostinger (plano compartilhado), PHP 8.1+ (8.3 recomendado) com pdo_mysql, gd, fileinfo, exif, mbstring e curl.
Banco	MariaDB 10.11 (compatível com MySQL 8.0.16+). Instalador em /install com token que deve ser limpo após o uso.
Limites	Upload de 16 MB, POST de 20 MB, memória de 256 MB, execução de 120 s.
Backup	Backups automáticos do hPanel (banco e arquivos). A pasta storage/ precisa estar incluída e a restauração deve ser testada.
Atualização	Subir o pacote por cima dos arquivos; o sistema aplica as migrações sozinho e publica as “novidades” da versão.
Logs	Erros de aplicação vão para app_log; o usuário vê só um código de suporte (X-Request-Id).

12. Pontos de atenção e recomendações

Itens observados na análise do código e das capturas de tela. Estão em ordem aproximada de prioridade.

#	Ponto	Recomendação
1	**Cron não está rodando em produção.** O Painel da direção mostra o aviso de que as tarefas agendadas não rodaram na última hora (Figura 2).	Criar o Cron Job de 5 minutos no hPanel. Sem ele não há geração de mensalidades, lembretes, envio de e-mails, expiração de reposições nem limpeza de mídia.
2	**Credenciais no pacote.** O app/config.php contém senha do banco, chaves e tokens, e o LEIA-ME.md traz o token do instalador em uma URL. O zip também carrega sessões e fotos reais de produção.	Trocar a senha do banco e os tokens, esvaziar install_token, não compartilhar o zip e excluir storage/sessions e storage/media do pacote de atualização.

#	Ponto	Recomendação
3	**Mercado Pago em modo de teste/validação.** A tela de cartão da mensalidade exibe erro sobre credencial “real ou de teste” (Figura 6, ao fundo).	Confirmar se o Access Token é de produção e testar um pagamento real de baixo valor antes de divulgar aos alunos.
4	**Sem testes automatizados** e com regras financeiras complexas (rateio, hora-aula, estorno).	Criar testes para finance.php e academic.php antes de novas mudanças; manter ambiente de homologação com cópia do banco.
5	**Monólito com arquivos longos** (lib/finance.php com 1,3 mil linhas; módulos de 400 a 830 linhas) e HTML misturado ao PHP.	Evoluir por partes: separar camada de consulta, extrair views e documentar os fluxos críticos.
6	**E-mail via mail() do servidor** costuma cair em spam e não dá relatório de entrega.	Migrar para SMTP autenticado ou serviço transacional e configurar SPF e DKIM do domínio.
7	**Domínio provisório** (aqua-yak-316559.hostingersite.com/forrodorei) e identidade visual declarada como provisória.	Registrar domínio próprio, atualizar app_url, webhook e remetente de e-mail.
8	**Dependência de poucos administradores** e do perfil Desenvolvedor, que concede e revoga a si mesmo.	Documentar quem detém o acesso, manter ao menos dois administradores com 2º fator e guardar os códigos de recuperação.

Escopo e limites deste documento
Briefing baseado na leitura do código do pacote “forrodorei-atualizacao” e em oito capturas de tela. Não foi possível executar o sistema nem consultar o banco de produção; números como alunos pagantes ou valores recebidos aparecem apenas nas capturas e refletem o ambiente de teste. A tela de pagamento hospedada pelo Mercado Pago foi omitida por conter dados de cartão de uma pessoa.